

Plan de Răspuns la Incidente

SecureHealth Systems Inc.

1. Introducere

Într-o companie ca SecureHealth Systems Inc., care lucrează direct cu tehnologie medicală și gestionează zilnic date sensibile despre sănătatea pacienților, un incident de securitate nu e doar o problemă tehnică – e o situație de risc real pentru oameni. De aceea, acest plan are un scop simplu, dar vital: să ne asigure că știm exact ce avem de făcut în momentul în care ceva merge prost.

Un astfel de plan este important pentru că:

- Ajută echipa să acționeze rapid, fără panică.
- Minimizați riscurile legale și reputaționale.
- Protejează informațiile medicale personale și confidențiale.
- Oferă o structură clară pentru recuperare și prevenirea viitoarelor incidente.

Gândim acest plan ca un ghid practic, nu un document formal pus într-un sertar. Scopul este să fie utilizat efectiv, în teren, atunci când apare un atac cibernetic, o scurgere de date sau un comportament suspect în sistem.

2. Echipa de Răspuns la Incidente (IRT)

2.1 Cine face parte din echipă și cum poate fi contactată

Pentru a răspunde eficient la incidente, avem o echipă dedicată, formată din oameni din mai multe departamente – IT, juridic, PR. Fiecare are un rol clar, iar comunicarea dintre ei este esențială.

Nume	Rol	E-mail	Telefon
Andrei Popescu	CISO – Lider echipă	andrei.popescu@securehealth.com	+40 721 000 001
Maria Ionescu	Analist Securitate IT	maria.ionescu@securehealth.com	+40 721 000 002
Radu Vasile	Inginer de Rețea	radu.vasile@securehealth.com	+40 721 000 003
Laura Dobre	Juridic & Conformitate	laura.dobre@securehealth.com	+40 721 000 004
Mihai Tudor	Comunicare & Relații Publice	mihai.tudor@securehealth.com	+40 721 000 005

2.2 Ce face fiecare

- CISO (Andrei Popescu) – Coordonează tot procesul. Ia deciziile majore, stabilește dacă incidentul e critic, ține legătura cu top managementul.
- Maria Ionescu (Analist IT) – Verifică alertele de securitate, analizează fișiere suspecte, ajută la detectarea și oprirea atacurilor.
- Radu Vasile (Rețea) – Se ocupă de infrastructura rețelei. În caz de incident, oprește accesul extern, izolează sistemele afectate, asigură continuitatea.
- Laura Dobre (Legal) – Ne ajută să respectăm legile privind protecția datelor. Decide dacă trebuie să anunțăm autoritățile sau clienții.
- Mihai Tudor (PR) – Se ocupă de comunicarea oficială. Evită panicarea publicului sau a presei, răspunde profesionist întrebărilor.

3. Pregătire

3.1 Politici și proceduri existente

Înainte să apară orice problemă, trebuie să fim bine pregătiți. Avem deja implementate următoarele politici:

- Politica de securitate IT – stabilește regulile generale privind accesul la sistem.
- Politica de backup – face backup automat la date zilnic și păstrează copii în locații sigure.
- Procedura de raportare a incidentelor – orice angajat poate raporta un comportament suspect printr-un formular simplu.
- Plan de continuitate – asigură că putem continua activitatea esențială chiar și în timpul unui atac.

3.2 Instrumente și resurse

Pentru a detecta și răspunde la incidente, folosim:

- Sistem SIEM – colectează și analizează automat logurile (de exemplu, Splunk).
- Soluții antivirus și EDR – protejează fiecare calculator și server în parte.
- Firewall și sistem de detectare a intruziunilor – blochează accesul neautorizat.
- Instrumente de analiză forensic – ne ajută să investigăm ce s-a întâmplat (ex: FTK Imager).
- Ghiduri (playbook-uri) pentru situații specifice, cum ar fi phishing sau ransomware.

4. Identificare și Analiză

4.1 Cum identificăm un incident?

- Verificăm în permanență logurile din servere, aplicații și firewall.
- Folosim alerte automate care se activează dacă cineva încearcă să acceseze un fișier restricționat.
- Angajații sunt încurajați să raporteze e-mailuri suspecte sau probleme tehnice neobișnuite.

4.2 Cum analizăm incidentul?

- Analizăm logurile din SIEM pentru a vedea cine, când și cum a accesat sistemul.
- Comparăm fișierele recente cu cele din backup (semnătură malware, modificări neautorizate).
- Testăm fișiere suspecte într-un mediu izolat (sandbox).
- Folosim instrumente forensic pentru a reconstitui pașii atacatorului.

5. Limitare, Eliminare și Recuperare

5.1 Limitarea pagubelor

- Scoatem din rețea calculatoarele afectate imediat.
- Dezactivăm conturile compromise.
- Oprim temporar serviciile afectate pentru a preveni răspândirea.

5.2 Eliminarea amenințării

- Ștergem fișierele infectate și verificăm dacă mai există urme.
- Resetăm toate parolele implicate.
- Facem update la sistemele vulnerabile.
- Blocăm IP-urile sau conturile atacatorului.

5.3 Recuperarea

- Restaurăm datele din backup-uri verificate.
- Testăm sistemele restaurate înainte să le reconectăm la rețea.
- Monitorizăm atent următoarele zile pentru a ne asigura că nu mai sunt probleme.
- Documentăm tot procesul și stabilim ce trebuie îmbunătățit.

6. Activități Post-Incident

6.1 Raportarea incidentului

- Facem un raport intern cu toate detaliile (ce, când, cum, cine).
- Dacă a fost afectată securitatea datelor pacienților, îi informăm oficial.
- Anunțăm autoritățile în termenul legal (ex: 72h către ANSPDCP).

6.2 Analiza cauzei și a impactului

- Investigăm de ce a fost posibil incidentul: o vulnerabilitate? o eroare umană?
- Estimăm costurile (financiare, reputaționale, operaționale).
- Evaluăm dacă planul a fost aplicat corect și ce am putea face mai bine.

6.3 Îmbunătățirea planului

- Actualizăm procedurile și playbook-urile.
- Instruim echipa – facem traininguri și simulări reale.
- Adăugăm noi măsuri de prevenție dacă e cazul (ex: autentificare multifactor, alerte mai stricte)

Concluzie

Incidentele nu pot fi prevenite 100% – dar felul în care reacționăm face toată diferența. Cu acest plan, SecureHealth Systems Inc. are un cadru clar, detaliat și practic pentru a răspunde rapid, a proteja datele pacienților și a învăța din fiecare experiență.